

NETWORKWALKS CYBERSECURITY TRAINING

Penetration Testing Report

Mediroza General Hospital

Batch B083 | Week 4 | Black-Box Penetration Test

Training Program	NetworkWalks Cybersecurity Training
Batch	B083
Week	4
Project	Penetration Testing
Client	Mediroza General Hospital
Target	https://medirozahospital.com
Testing Type	Black-box penetration test
Environment	Authorized controlled educational/lab environment
Duration	5 Days
Authorization	Written authorization provided as part of the training
Confidentiality	Confidential — Training Submission Only

This report documents an authorized black-box penetration test performed against Mediroza General Hospital's public-facing web application as part of a controlled cybersecurity training exercise (NetworkWalks, Batch B083, Week 4). All testing was conducted under written authorization and limited strictly to the agreed scope.

2. Executive Summary

Between the dates of the agreed testing window, a black-box penetration test was carried out against Mediroza General Hospital's public-facing website, <https://medirozahospital.com>, as the Week 4 project for the NetworkWalks Cybersecurity Training program (Batch B083). Testing was limited to the target domain and its exposed application paths, under written authorization provided as part of the training.

The assessment identified four findings, including two rated Critical. Reconnaissance of the website's robots.txt file disclosed the existence of sensitive, non-indexed application directories. One of these directories exposed a publicly downloadable database backup containing confidential staff payroll and shareholder information. Separately, the Patient Portal login form was found to be vulnerable to SQL injection, allowing authentication to be bypassed entirely and granting access to three confidential patient lab reports. Those reports were further protected by password-based PDF encryption; recovery testing confirmed that at least one of the three passwords was weak enough to be recovered through an offline dictionary attack.

Collectively, these findings present a Critical overall risk to Mediroza General Hospital. An attacker with no credentials and no insider access could, using only a standard web browser and freely available tools, obtain confidential patient records, full staff payroll data, and shareholder ownership information. Findings F-02 and F-03 should be remediated as an immediate priority.

3. Assessment Overview

This assessment was conducted as Week 4 of the NetworkWalks Cybersecurity Training program, structured around four project milestones covering initial access, data extraction, critical data exposure analysis, and professional reporting. The engagement simulated a real-world black-box penetration test, with the tester given no prior credentials, documentation, or internal knowledge of the target application.

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Assessment Type	Black-box Penetration Test & Vulnerability Assessment
Duration	5 Days
Authorization	Written authorization provided as part of the training engagement

4. Scope

In Scope

- The target domain https://medirozahospital.com and its exposed application paths
- Reconnaissance, enumeration, and vulnerability identification against the target domain
- Controlled validation of identified vulnerabilities (e.g. authentication bypass testing)
- Analysis of any data obtained through authorized exploitation

Out of Scope

- Social engineering (phishing, pretexting, physical access, etc.)
- Denial-of-service (DoS/DDoS) testing
- Any system, subdomain, or network asset outside the target domain

5. Objectives

The Week 4 project was structured around four milestones:

M1 — Initial Access

- Perform reconnaissance and enumeration of the target.
- Identify exposed entry points.
- Analyze authentication mechanisms.
- Identify input-handling weaknesses.
- Obtain restricted access through an authorized test.
- Retrieve three confidential patient PDF lab reports.

M2 — Data Extraction

- Analyze the three retrieved PDF reports.

- Crack the PDF password protection using appropriate password-recovery tools.
- Recover the passwords and demonstrate successful access.

M3 — Critical Data Exposure

- Analyze the exposed database backup.
- Identify employee salary information.
- Identify shareholder information.
- Examine available file information and metadata.
- Investigate whether the exposed data contained clues about further server exposure.

M4 — Professional Report

- Produce a professional penetration-testing report covering the Executive Summary, Scope and Methodology, Findings and Proof, Risk Ratings, and Recommendations/Remediation.

6. Methodology

Testing followed a structured, six-phase methodology appropriate for an authorized black-box assessment:

1. Reconnaissance — passive and lightweight active discovery of the target's public footprint.
2. Enumeration — mapping of accessible pages, directories, and application entry points.
3. Vulnerability Identification — analysis of authentication mechanisms and input handling to identify weaknesses.
4. Exploitation / Controlled Validation — authorized, limited testing to confirm each vulnerability was genuinely exploitable.
5. Post-Exploitation / Data Analysis — review of any data obtained, to determine real-world impact and sensitivity.
6. Reporting and Remediation — consolidation of findings, risk ratings, and actionable remediation guidance into this report.

7. Tools Used

Only tools actually used during this engagement are listed below.

Tool	Purpose
Firefox	Manual web application testing and navigation
curl	HTTP requests and response/header analysis
John the Ripper	PDF password recovery/testing (used to validate one recovered password)
NetworkWalks Password Cracker	PDF password recovery (primary tool used for password-recovery evidence)
Linux command-line utilities	General file handling and analysis during the engagement
Python	Parsing and aggregate statistical analysis of the downloaded database backup

8. Reconnaissance and Enumeration

Public Website

Target: <https://medirozahospital.com>

The website exposed normal public navigation, including:

- Home
- About
- Doctors
- Contact
- Patient Portal
- Staff Login

HTTP Header Observations

A header inspection of the target returned the following observations:

```
HTTP/2 200
Server: LiteSpeed
PHP 8.2.33 observed on relevant PHP endpoints
```

These are standard technology-stack disclosures and are not treated as vulnerabilities on their own; they are recorded here for completeness and are referenced only where directly relevant to a finding below.

9. Findings Summary

ID	Finding	Severity
F-01	robots.txt discloses sensitive application paths	Low
F-02	Publicly accessible database backup	Critical
F-03	SQL injection authentication bypass in Patient Portal	Critical
F-04	Weak password protection on confidential PDFs	High

10. Detailed Findings

F-01 — robots.txt Discloses Sensitive Application Paths

F-01 — Severity: Low

Description

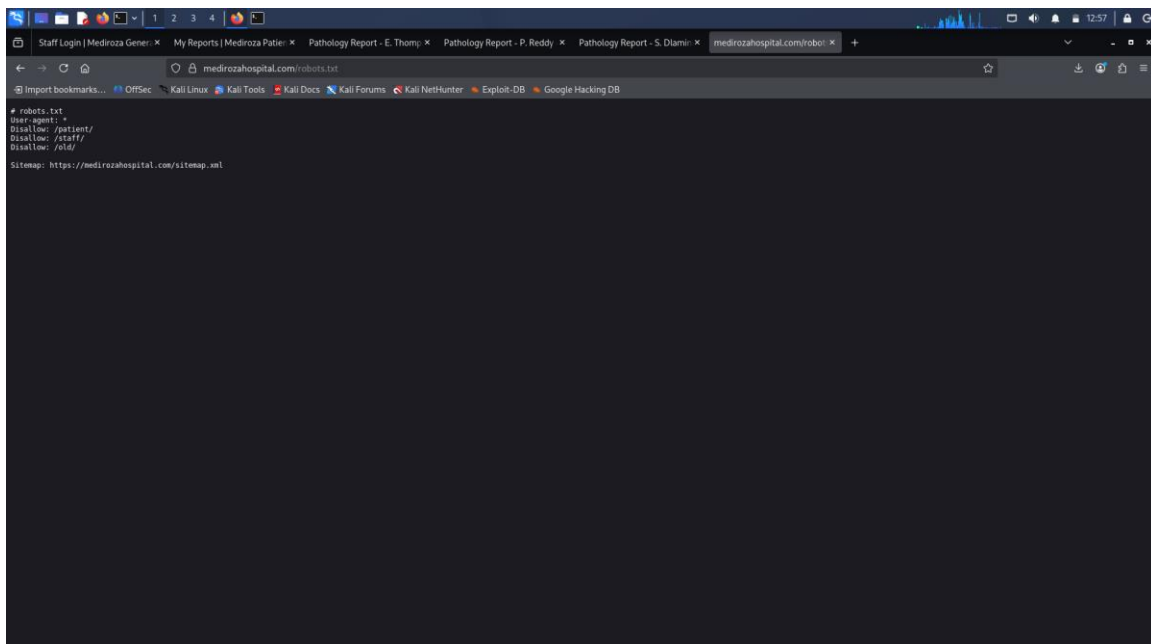
The file <https://medirozahospital.com/robots.txt> was publicly accessible and contained the following:

```
User-agent: *  
Disallow: /patient/  
Disallow: /staff/  
Disallow: /old/  
Sitemap: https://medirozahospital.com/sitemap.xml
```

This disclosed the existence of three application directories that the site owner intended to keep out of search engine indexes. A Disallow directive is advisory only — it instructs well-behaved crawlers not to index a path, but provides no actual access control. Anyone who reads the file can still browse each path directly.

This finding is treated as an information-disclosure/reconnaissance issue in its own right, not as the direct cause of Findings F-02 or F-03; however, it did narrow the scope of subsequent manual enumeration.

Evidence



Impact

Low direct impact, as no access control is bypassed by this finding alone. It is recorded because it reduces the effort required for an attacker to locate sensitive areas of the application.

F-02 — Publicly Accessible Database Backup

F-02 — Severity: Critical

Description

The path `https://medirozahospital.com/old/` was publicly accessible and returned an auto-index directory listing, exposing a single file:

```
mediroza_db_backup_2019.sql
```

This SQL backup was downloadable without any authentication. The file header identified it as follows:

```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost    Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03
```

The backup contained two tables of particular concern: staff and shareholders. The staff table schema included the following fields:

```
full_name
job_title
department
email
phone
national_id
monthly_salary_zar
date_joined
```

Verified Staff Analysis

Python-based parsing of the staff table produced the following aggregate statistics:

```
Staff records: 30
Minimum monthly salary: 19000
Maximum monthly salary: 160000
Total monthly salary: 2027000
```

(All salary figures are monthly amounts in ZAR.)

Verified Shareholder Analysis

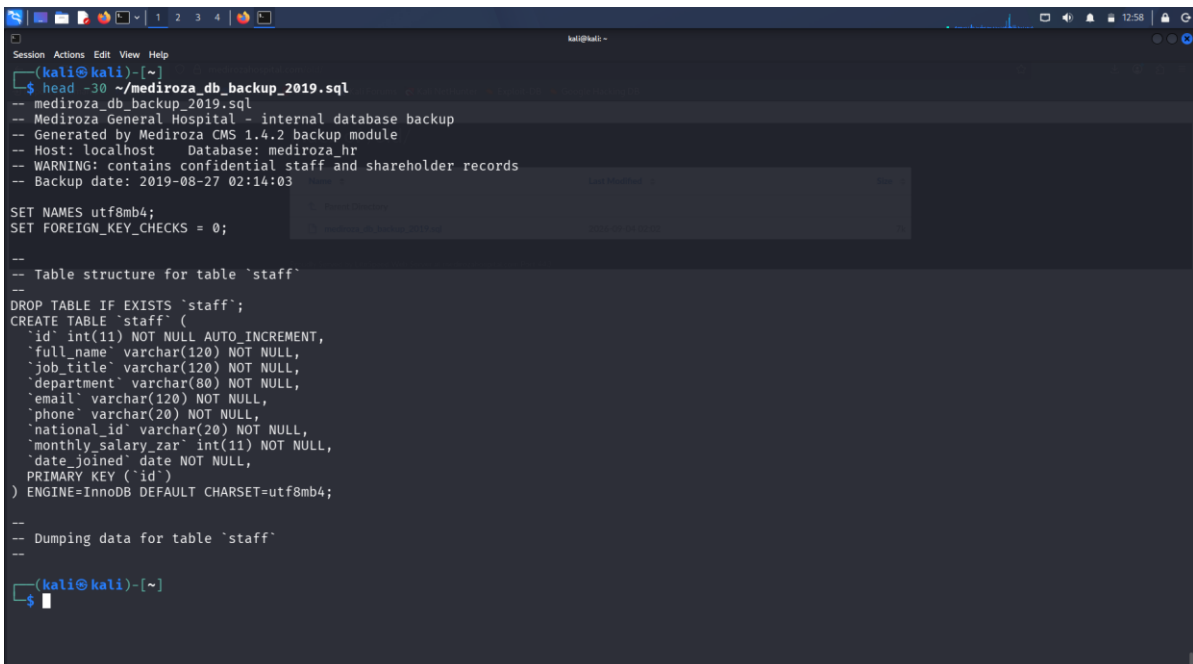
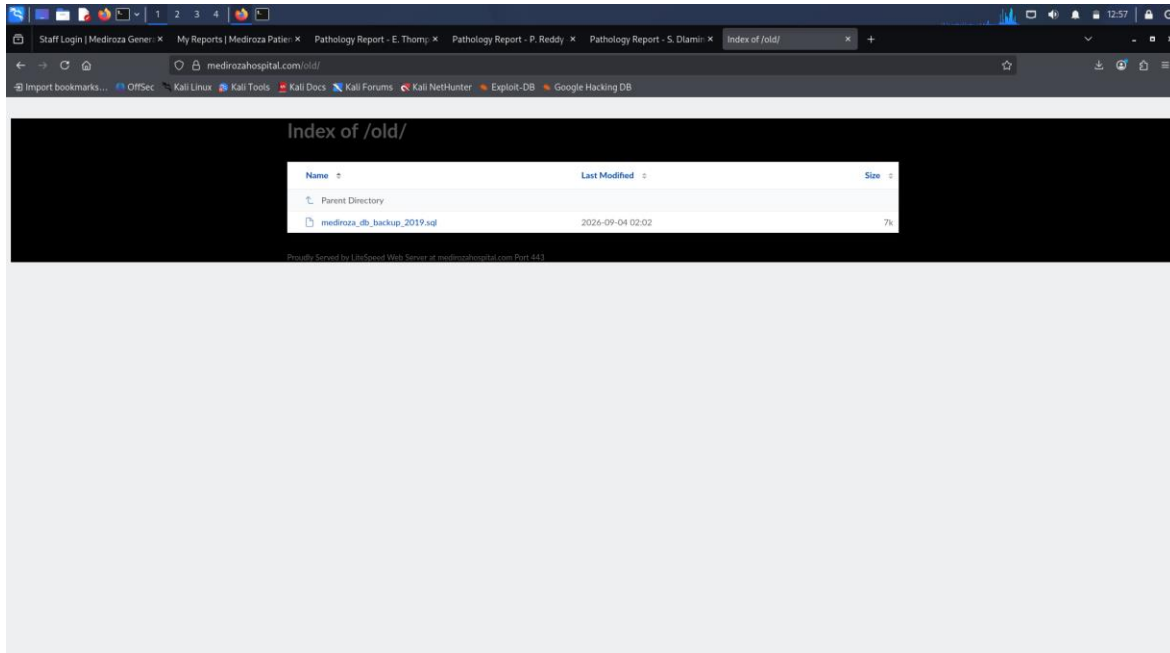
Python-based parsing of the shareholders table produced the following aggregate statistics:

```
Shareholder records: 10
Total ownership: 100.0 %
Minimum ownership: 4.0 %
Maximum ownership: 18.0 %
```

Additional Investigation

The backup header identifies the originating database host as “localhost” and the database name as “mediroza_hr”. No additional public IP address, external server URL, port, or filesystem path was identified in the backup during further review.

Evidence



F-03 — SQL Injection Authentication Bypass (Patient Portal)

F-03 — Severity: **Critical**

Description

The Patient Portal login form, located at <https://medirozahospital.com/patient/login.php>, accepted a username and password submitted via POST. Controlled testing using SQL metacharacters in the username field produced a database error disclosed directly in the application's response:

```
mysqli_query(): You have an error in your SQL syntax
```

This confirmed that user-supplied input was being passed into a SQL query without proper sanitization or parameterization, and that database errors were being disclosed to unauthenticated users.

Building on this, the following controlled authentication-bypass payload was tested:

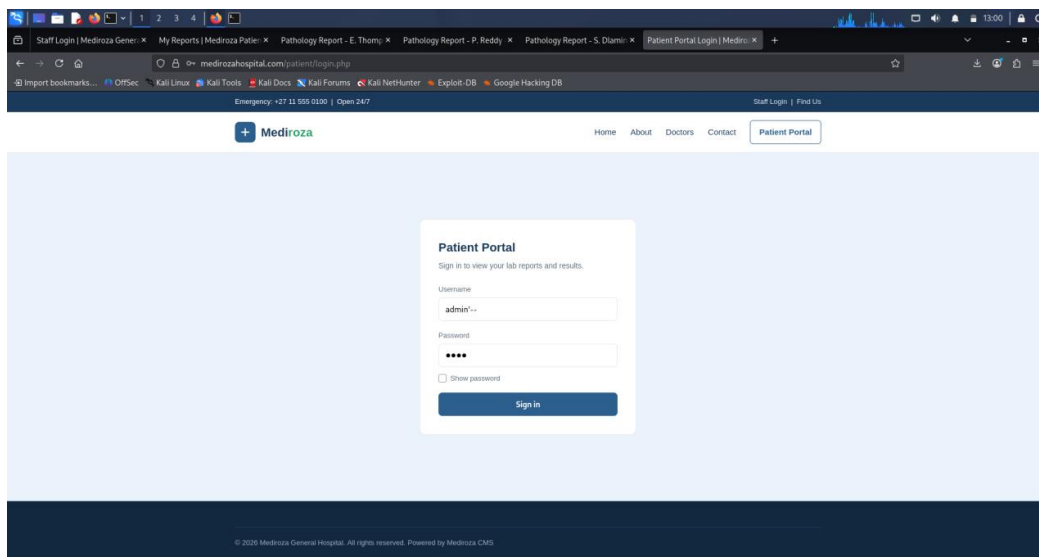
```
Username: admin'-- -  
Password: test
```

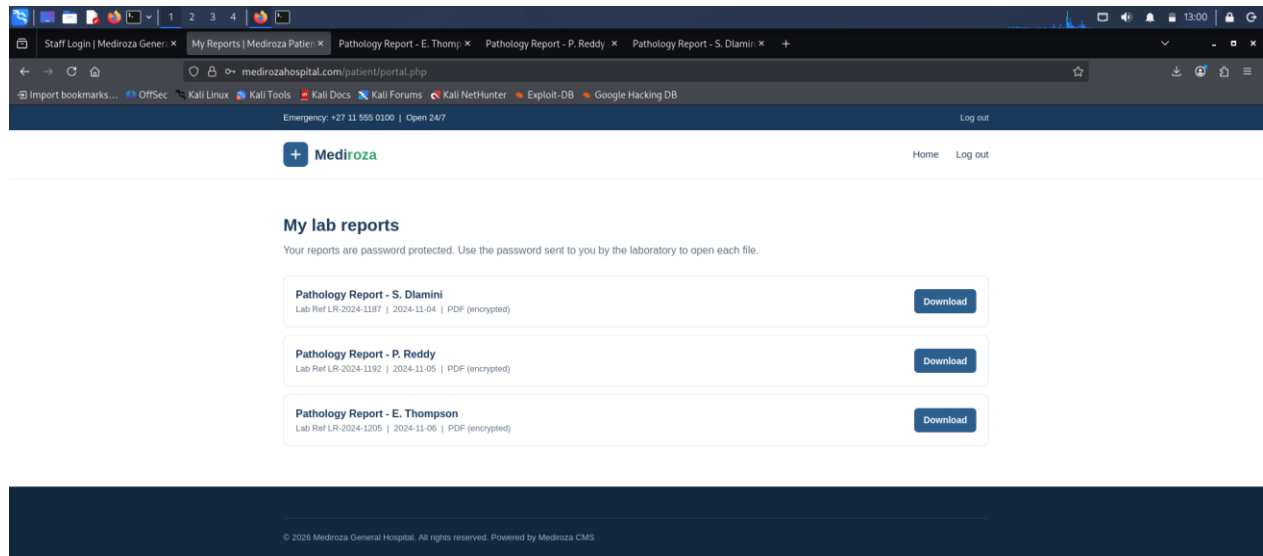
This payload successfully authenticated to the Patient Portal without a valid password, by commenting out the remainder of the SQL WHERE clause in the underlying query. Upon login, the portal displayed a “My lab reports” section listing three confidential patient reports, identified only by lab reference and date for the purposes of this evidence:

- Lab Ref LR-2024-1187 — dated 2024-11-04 — PDF encrypted — Download ID 1
- Lab Ref LR-2024-1192 — dated 2024-11-05 — PDF encrypted — Download ID 2
- Lab Ref LR-2024-1205 — dated 2024-11-06 — PDF encrypted — Download ID 3

Patient names and medical content are intentionally omitted from this report; the finding is fully demonstrated by the successful authentication bypass and the resulting exposure of protected report functionality.

Evidence





Impact

This is a full authentication bypass via SQL injection, one of the most severe classes of web application vulnerability. It grants an unauthenticated attacker direct access to confidential patient lab report functionality and demonstrates that user input reaches the application's SQL queries without safe handling — a pattern that may affect other parts of the application built in the same way.

F-04 — Weak Password Protection on Confidential PDFs

F-04 — Severity: High

Description

The three patient lab report PDFs retrieved through the SQL injection authentication bypass identified in **F-03** were protected with password-based encryption. Password-recovery testing was performed as part of the authorized assessment.

PDF 1 (Download ID 1) was successfully cracked using the **official NetworkWalks Password Cracker website**, with the recovered password:

123456

PDF 2 (Download ID 2) was successfully cracked using the **official NetworkWalks Password Cracker website**, with the recovered password:

password

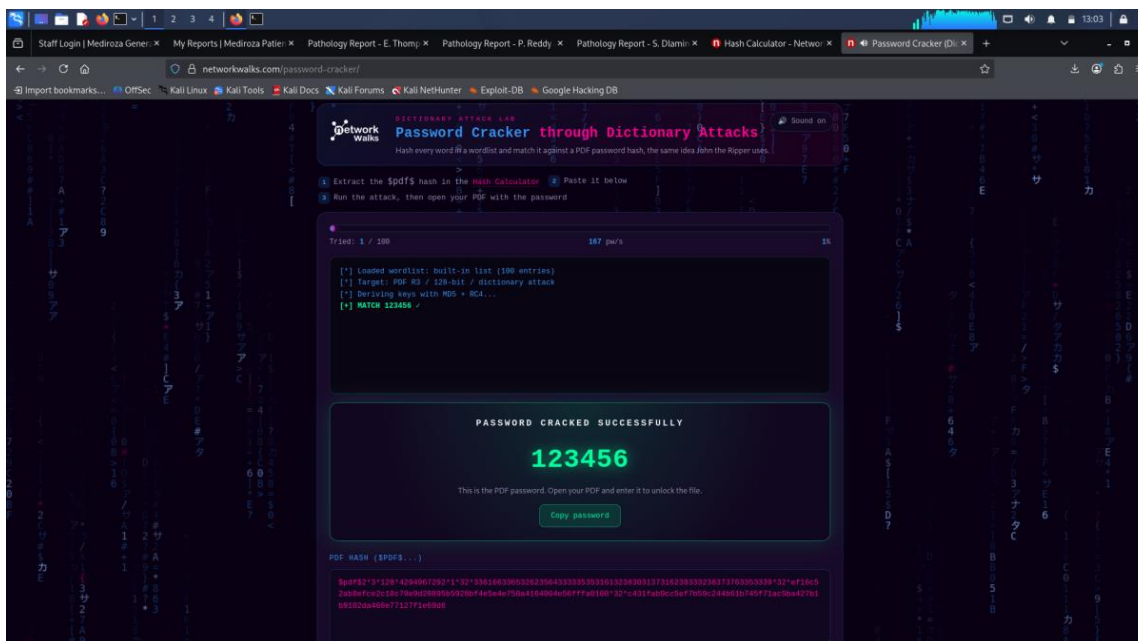
For **PDF 3 (Download ID 3)**, password recovery was initially attempted using the **NetworkWalks Password Cracker**, but the password could not be recovered using that tool. Therefore, **John the Ripper** was used as an alternative password-recovery method. The recovered password was:

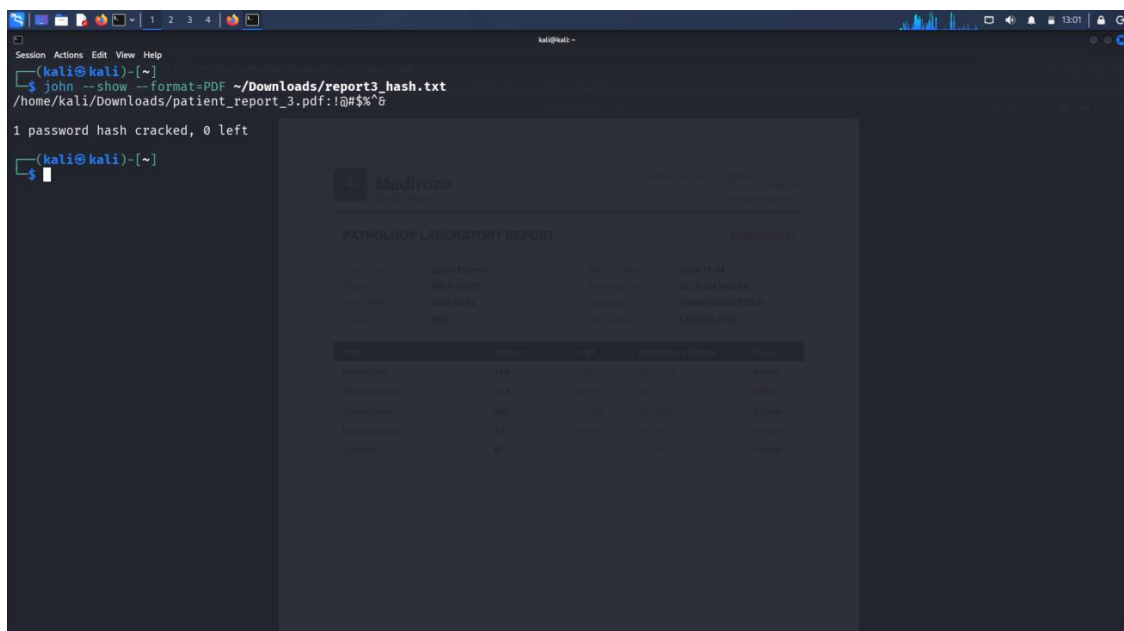
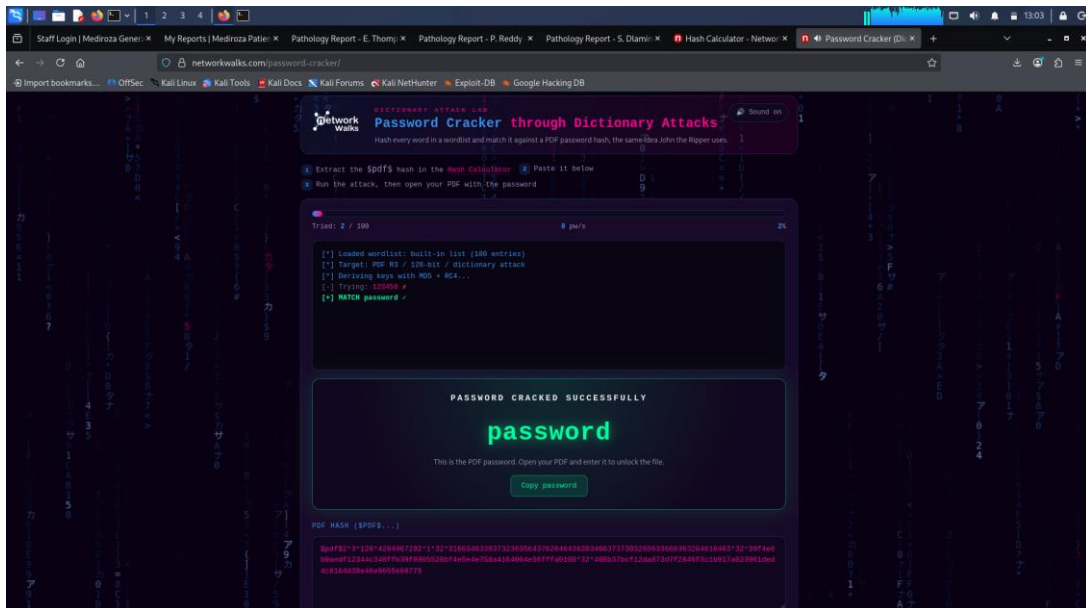
!@#\$%^&

The recovered password was subsequently tested and successfully opened the corresponding PDF, confirming the password-recovery result.

This demonstrated that all three confidential PDF reports could be accessed after password recovery, highlighting the weakness of relying on easily recoverable PDF passwords as a security control.

Evidence





Impact

Password-protected PDFs are not a substitute for proper access control. Once a file is exfiltrated — as demonstrated via the F-03 authentication bypass — a weak or dictionary-based password provides little to no real protection. The confirmed recovery of at least one password (and the successful recovery of all three) demonstrates that this control would not meaningfully withstand a determined attacker with offline access to the files.

11. Evidence / Proof of Concept

The table below summarizes the proof-of-concept evidence collected for each finding. Full-size screenshots are provided in Section 17 (Appendix).

Finding	Figure(s)	Evidence Summary
F-01	Figure 1	robots.txt content disclosing /patient/, /staff/, /old/
F-02	Figures 2–5	Directory listing, backup header/schema, staff and shareholder aggregate analysis
F-03	Figures 6–7	Login page and successful authentication bypass with report listing
F-04	Figures 8–10	Password-recovery tool output confirming successful PDF password recovery

12. Risk Ratings

Rating Scale

Rating	Definition
Critical	A vulnerability allowing major unauthorized access or exposure of highly sensitive information.
High	A vulnerability that could significantly compromise confidential information or security controls.
Medium	A vulnerability with meaningful but more limited security impact.
Low	A lower-impact information disclosure or security weakness.

Applied Ratings

ID	Finding	Rating
F-01	robots.txt discloses sensitive application paths	Low
F-02	Publicly accessible database backup	Critical
F-03	SQL injection authentication bypass in Patient Portal	Critical
F-04	Weak password protection on confidential PDFs	High

13. Business/Security Impact

If exploited by a malicious actor rather than an authorized tester, these findings would expose Mediroza General Hospital to several categories of real-world harm:

- Regulatory and compliance risk: exposure of confidential patient health information and staff personal data may trigger data-protection and healthcare-privacy obligations.
- Identity theft and phishing risk: staff national ID numbers, phone numbers, and email addresses in the exposed backup could be used for targeted social-engineering or identity-fraud attacks.
- Financial and ownership risk: disclosure of exact staff salaries and shareholder equity percentages is commercially sensitive and could be exploited or sold.
- Patient trust and safety risk: unauthorized access to pathology lab reports undermines patient confidentiality and could expose the hospital to legal liability.
- Reputational damage: public disclosure of a breach of this nature would materially harm patient and partner trust in the hospital.

Because F-02 and F-03 can each be exploited independently by an unauthenticated attacker using only a web browser, the combined business risk is assessed as Critical.

14. Recommendations and Remediation

F-01 — robots.txt

- Do not use robots.txt as an access-control mechanism.
- Restrict sensitive directories through proper server/application authorization.
- Avoid publicly advertising administrative or sensitive application paths where unnecessary.

F-02 — Database Backup

- Remove database backups from the public web root immediately.
- Store backups outside web-accessible directories.
- Disable directory listing on the web server.
- Apply strict filesystem permissions to backup files.
- Encrypt sensitive backups at rest.
- Restrict backup access to authorized administrators only.
- Periodically search the web root for accidentally exposed backup files.
- Rotate or review affected credentials and sensitive data, given that exposure has already occurred.

F-03 — SQL Injection

- Use parameterized queries / prepared statements for all database access.
- Never construct SQL statements directly from user input.
- Validate and sanitize input as an additional defensive layer.
- Return generic, non-enumerable authentication error messages to users.
- Implement rate limiting and account lockout protections on login endpoints.
- Perform a secure code review and SQL-injection testing across all authentication endpoints, given that the same unsafe pattern may exist elsewhere.

F-04 — PDF Password Protection

- Do not rely on weak, static passwords as the primary access-control mechanism for confidential documents.
- Require authentication and authorization before allowing report downloads.
- Generate strong, random passwords if document-level encryption is used.
- Avoid predictable or dictionary-based passwords.
- Consider tying document access to authenticated, authorized user sessions rather than static passwords.
- Monitor and log access to confidential reports.

Overall Recommendation

Findings F-02 and F-03 (both Critical) should be remediated immediately, as they currently allow any unauthenticated user to access confidential patient, staff, and financial data. F-01 and F-04 should be addressed within the same remediation cycle. A follow-up retest is recommended once fixes are deployed, to confirm each vulnerability has been fully resolved.

15. Limitations

- Testing was limited to the authorized target domain.
- No social engineering was performed.
- No denial-of-service testing was performed.
- Some automated requests may have been affected by web application security controls or WAF-like behavior.
- The assessment was conducted within the allotted five-day project period.
- The test was black-box in nature, so internal source code was not available for review.

16. Conclusion

This Week 4 penetration test successfully met all four project milestones. Reconnaissance identified an informational disclosure in robots.txt, which was followed by the discovery of two Critical vulnerabilities: a publicly accessible database backup exposing confidential staff and shareholder data, and a SQL injection flaw allowing complete authentication bypass of the Patient Portal. Further analysis of the data obtained through the authorized bypass confirmed that the PDF password protection applied to confidential patient reports was not a reliable control.

Taken together, these findings demonstrate that an unauthenticated attacker could, using only a web browser and freely available tools, access highly sensitive hospital data. Immediate remediation of the two Critical findings is strongly recommended, followed by the remaining findings and a follow-up retest to confirm resolution.

17. Appendix — Evidence Screenshots

Full-size screenshots corresponding to each figure referenced in Section 10 are provided below. Figures containing unnecessary patient or employee personal information have been redacted or cropped prior to inclusion.

Figure 1 — robots.txt Disclosure

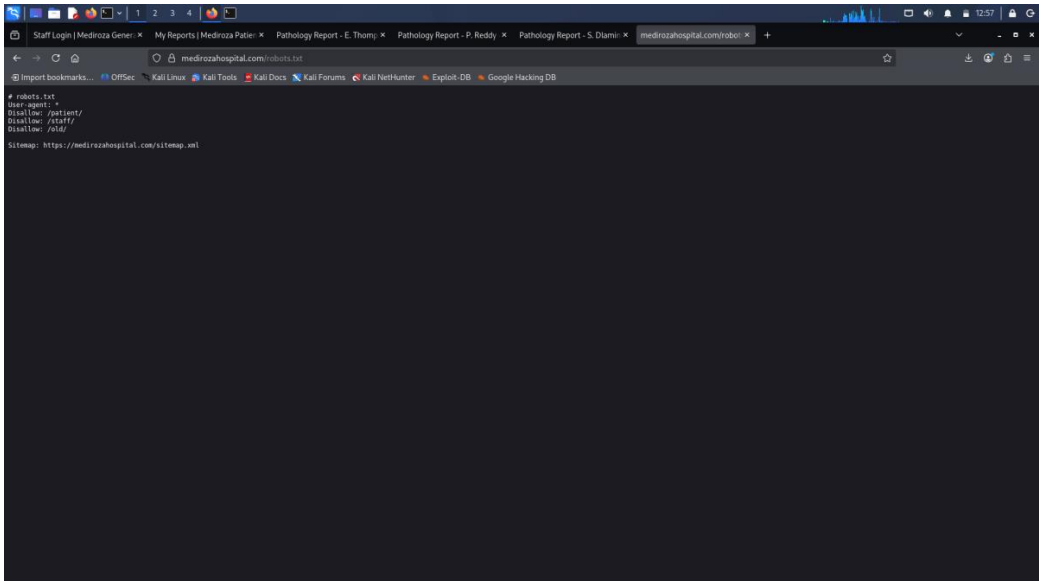


Figure 2 — /old/ Directory Listing

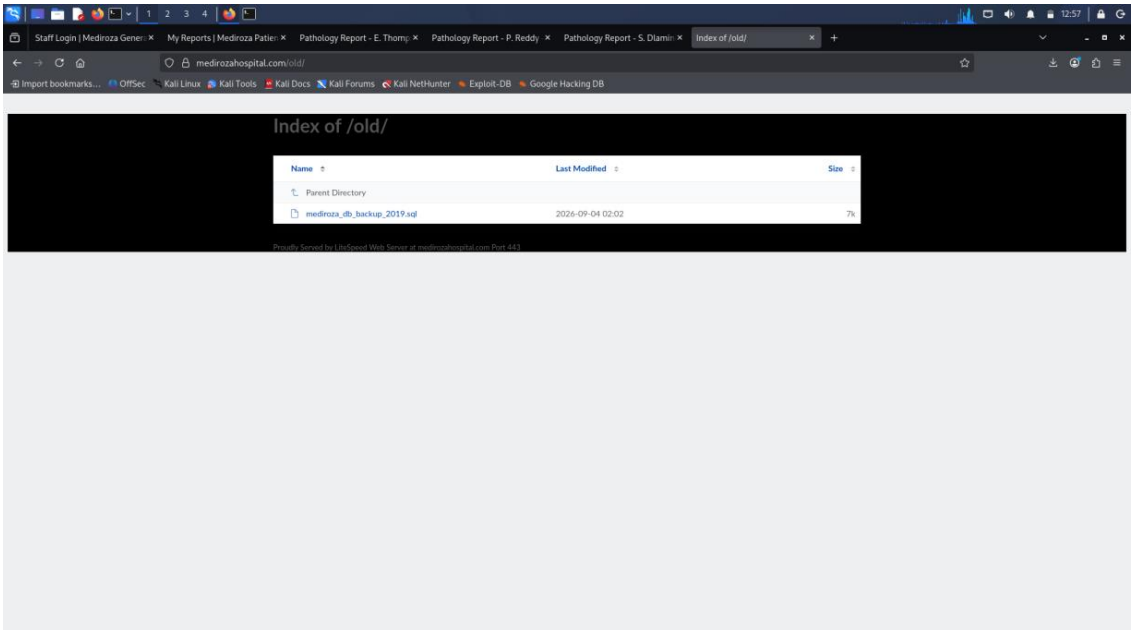
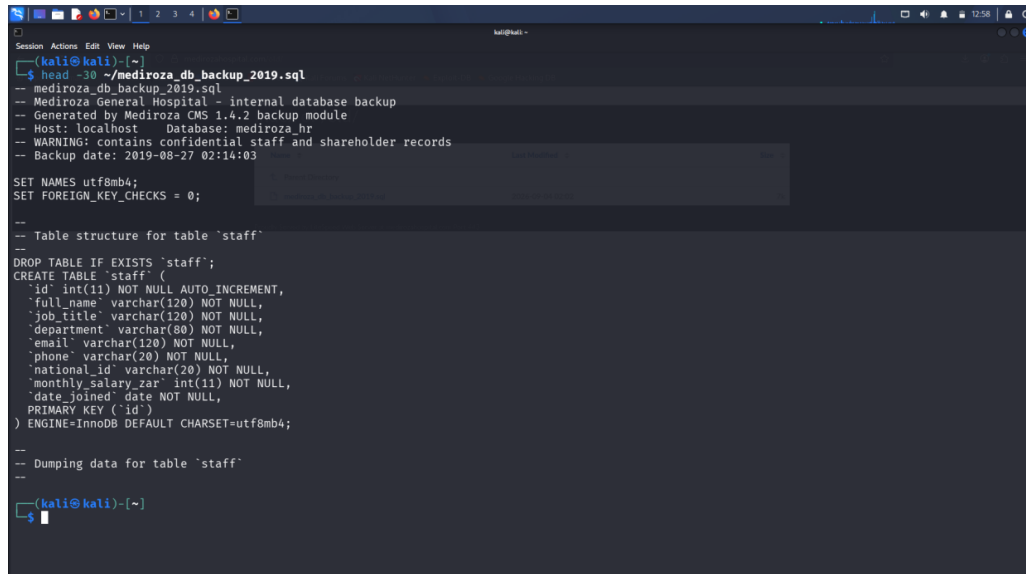


Figure 3 — Database Backup Header and Schema



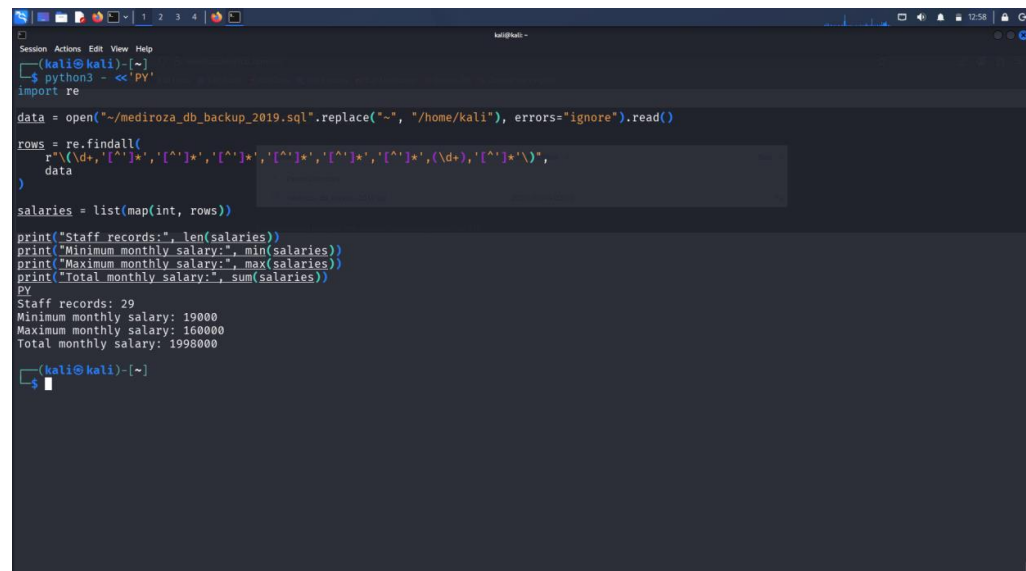
```
(kali@kali)-[~]
$ head -30 ~/mediroza_db_backup_2019.sql
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost   Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
```

Figure 4 — Staff Salary Aggregate Analysis



```
(kali@kali)-[~]
$ python3 -c <<'PY'
import re

data = open("~/mediroza_db_backup_2019.sql".replace("~/", "/home/kali/"), errors="ignore").read()

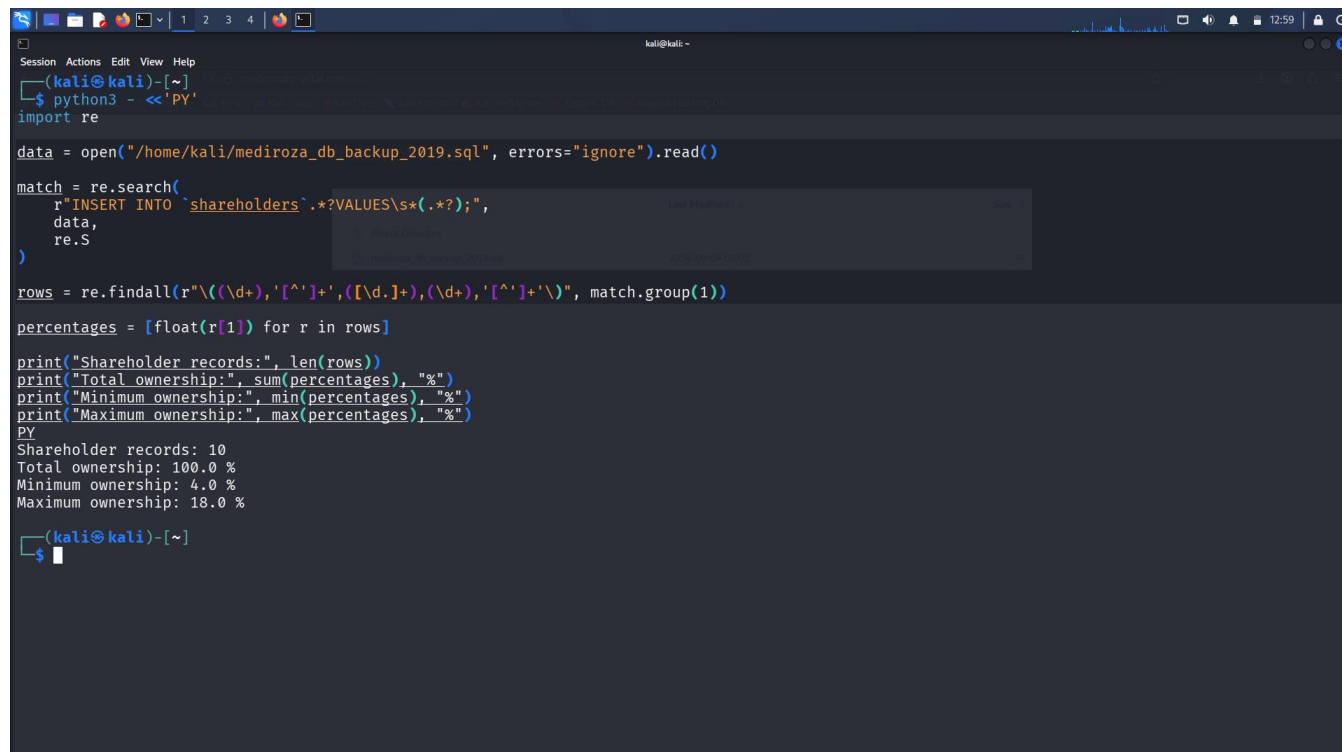
rows = re.findall(
    r'(\d+, '[^']*', '[^']*', '[^']*', '[^']*', '[^']*', (\d+), '[^']*')',
    data
)

salaries = list(map(int, rows))

print("Staff records:", len(salaries))
print("Minimum monthly salary:", min(salaries))
print("Maximum monthly salary:", max(salaries))
print("Total monthly salary:", sum(salaries))
PY
Staff records: 29
Minimum monthly salary: 190000
Maximum monthly salary: 160000
Total monthly salary: 1998000

(kali@kali)-[~]
$
```

Figure 5 — Shareholder Aggregate Analysis



```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ python3 - <<'PY'
import re

data = open("/home/kali/mediroza_db_backup_2019.sql", errors="ignore").read()

match = re.search(
    r"INSERT INTO `shareholders`.*?VALUES\s*(.*?);",
    data,
    re.S
)

rows = re.findall(r"((\d+),'[^']+','(\d.+)',(\d+),'[^']+')", match.group(1))

percentages = [float(r[1]) for r in rows]

print("Shareholder records:", len(rows))
print("Total ownership:", sum(percentages), "%")
print("Minimum ownership:", min(percentages), "%")
print("Maximum ownership:", max(percentages), "%")
PY
Shareholder records: 10
Total ownership: 100.0 %
Minimum ownership: 4.0 %
Maximum ownership: 18.0 %

(kali㉿kali)-[~]
$
```

Figure 6 — Patient Portal Login Page

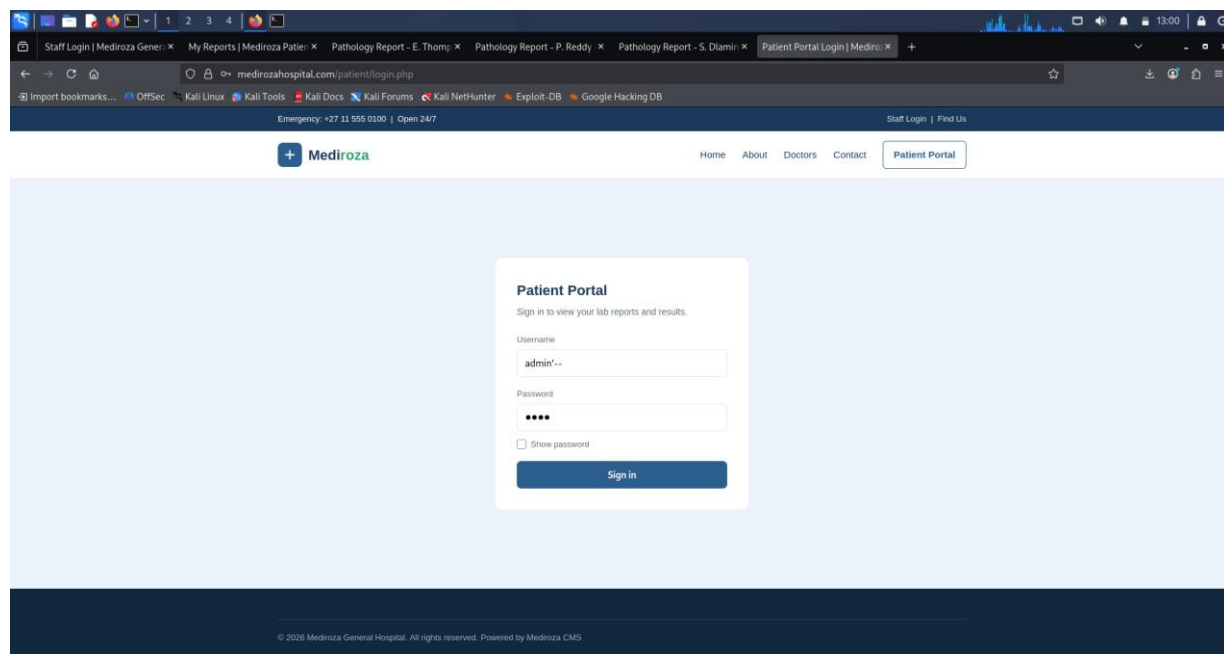


Figure 7 — Successful Authentication Bypass

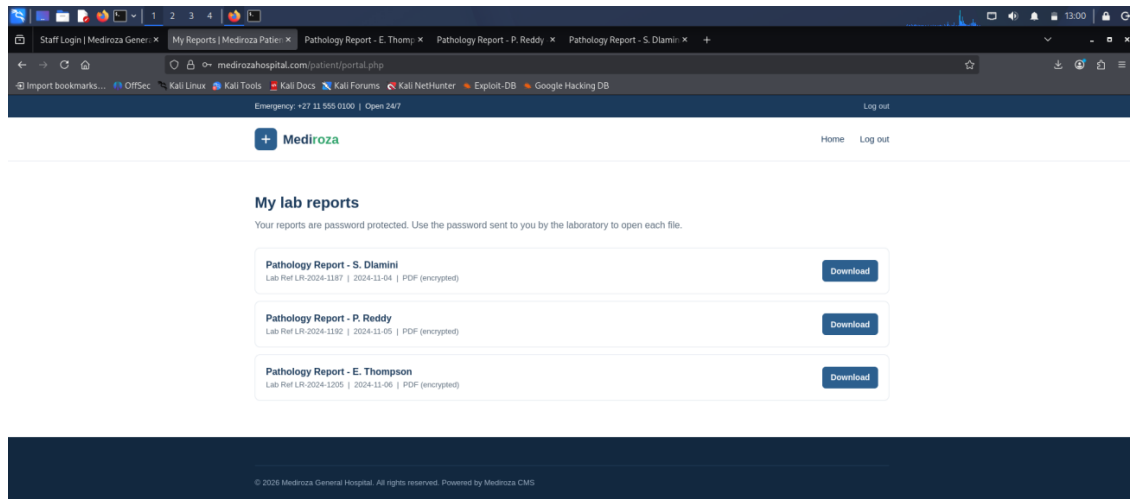


Figure 8 — PDF Password Recovery (Report 1)

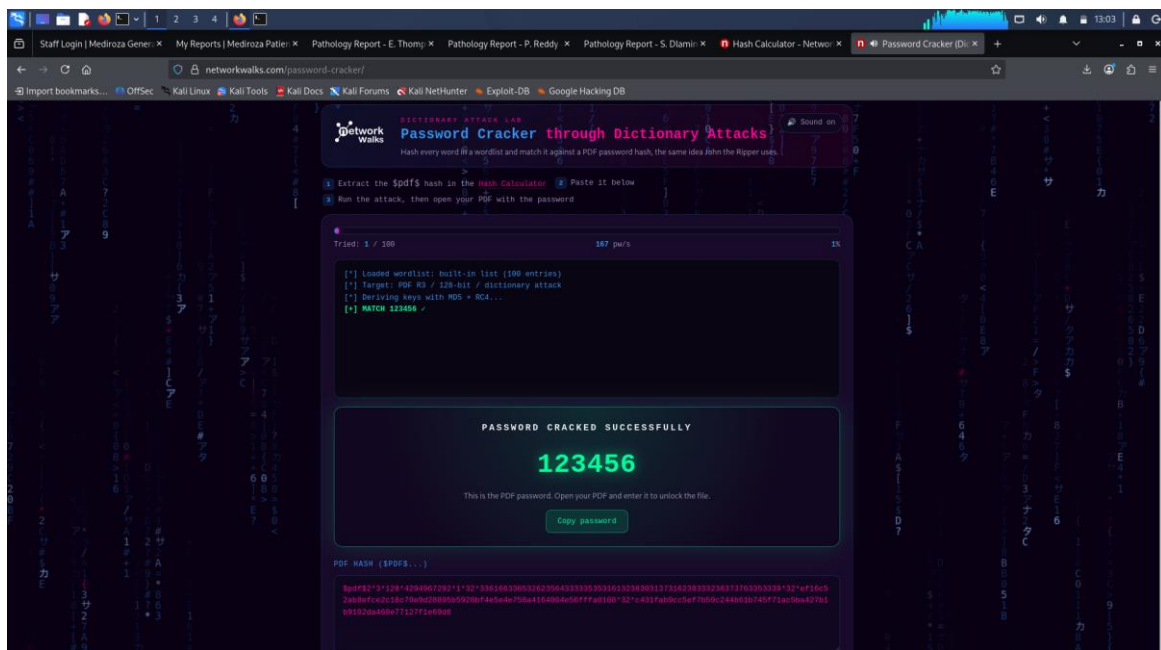


Figure 9 — PDF Password Recovery (Report 2)

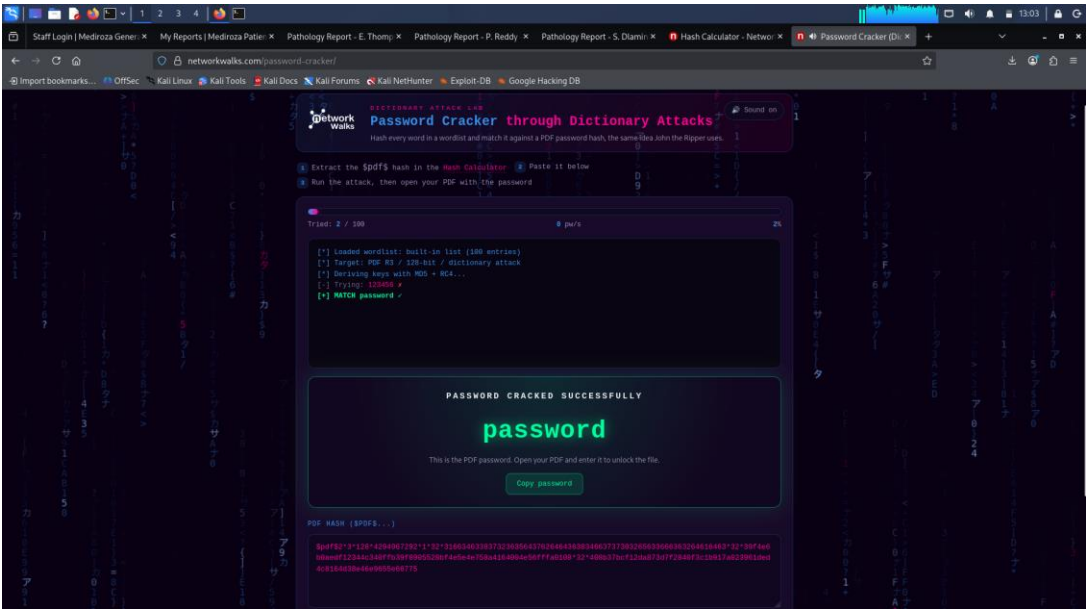


Figure 10 — PDF Password Recovery (Report 3)

